

Лекция 4. Угрозы и уязвимости в системах волоконно – оптической связи и беспроводных сетях

Учебные вопросы:

1. Понятие угрозы и уязвимости компьютерных сетей.
2. Виды сетевых атак.
3. Угрозы и уязвимости беспроводных сетей.

1. Понятие угрозы и уязвимости компьютерных сетей.

Основным свойством, отличающим компьютерные сети от автономных компьютеров, является наличие обмена информацией между сетевыми узлами, связанными линиями передачи данных. Объединение компьютеров в компьютерные сети позволяет значительно повысить эффективность использования компьютерной системы в целом. Повышение эффективности при этом достигается за счет возможности обмена информацией между компьютерами сети, а также за счет возможности использования на каждом компьютере общих сетевых ресурсов (информации, внешней памяти, программных приложений, внешних устройств).

Основная задача, решаемая, при создании компьютерных сетей – обеспечение совместимости оборудования по электрическим и механическим характеристикам, а также по совместимости информационного обеспечения (программ и данных) по системам кодирования и формату данных. Решение этой задачи относится к области стандартизации. Методологической основой стандартизации в компьютерных сетях является многоуровневый подход к разработке средств сетевого взаимодействия. На основе этого подхода и технических предложений Международного института стандартов ISO (International Standards Organization) в начале 1980 х годов была разработана стандартная модель взаимодействия открытых систем

OSI (Open Systems Interconnection). Модель ISO/OSI сыграла важную роль в развитии компьютерных сетей.

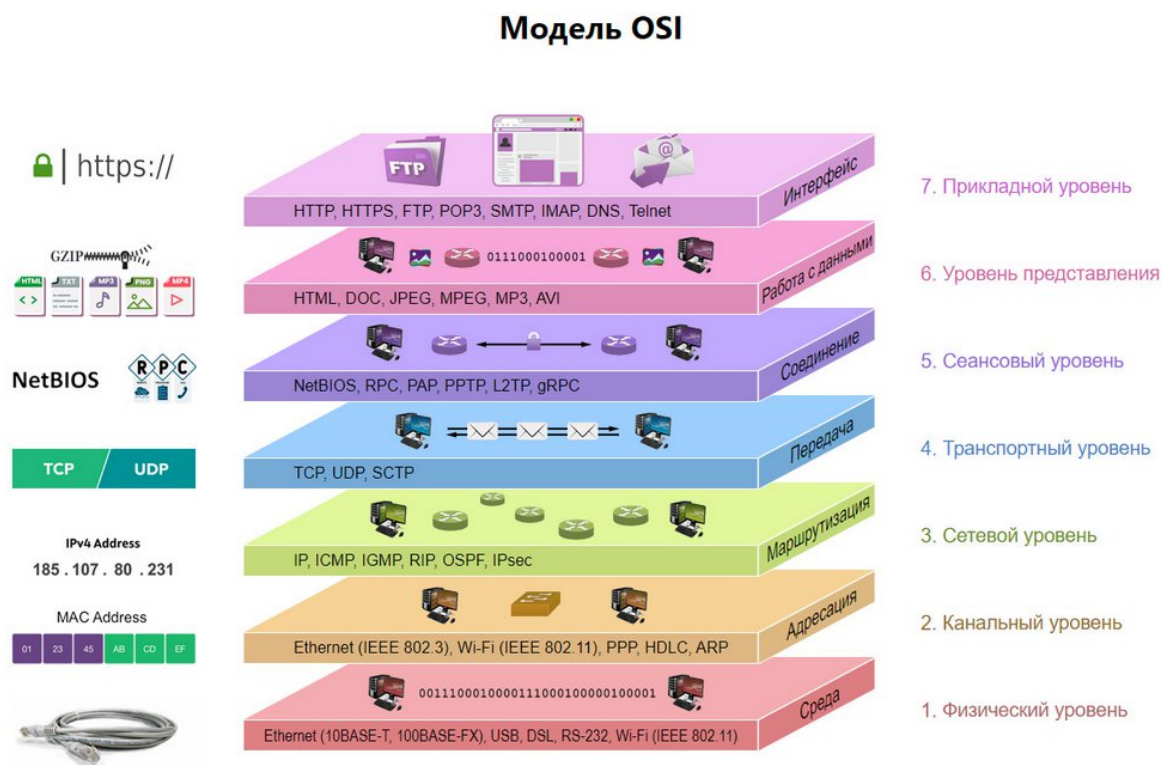


Рисунок 1. Модель OSI

Для организации коммуникаций в неоднородной сетевой среде применяется набор протоколов TCP/IP, обеспечивая совместимость между компьютерами разных типов. Совместимость – одно из основных преимуществ TCP/IP, поэтому большинство компьютерных сетей поддерживает эти протоколы. Кроме того, протоколы TCP/IP предоставляют доступ к ресурсам глобальной сети Интернет. Благодаря своей популярности TCP/IP стал стандартом для межсетевого взаимодействия. Однако повсеместное распространение стека протоколов TCP/IP обнажило и его слабые стороны. Стремительный рост популярности интернет-



технологий сопровождается ростом серьезных угроз разглашения персональных данных, критически важных корпоративных ресурсов, государственных тайн и т.д.

Специалисты спецслужб в области ИТ и злоумышленники подвергают угрозам сетевые информационные ресурсы, пытаясь получить к ним доступ с помощью специальных атак. Эти атаки становятся все более изощренными по воздействию и несложными в исполнении. Этому способствуют два основных фактора.

Во-первых, это повсеместное использование Интернета. Сегодня к этой сети подключены миллионы компьютеров. Многие миллионы компьютеров будут подключены к Интернету в ближайшем будущем, поэтому вероятность доступа к уязвимым компьютерам и компьютерным сетям постоянно возрастает. Кроме того, широкое распространение Интернета позволяет хакерам обмениваться информацией в глобальном масштабе.

Во-вторых, это всеобщее распространение простых в использовании операционных систем и сред разработки. Этот фактор резко снижает требования к уровню знаний злоумышленника. Раньше от нарушителя требовались хорошие знания и навыки программирования, чтобы создавать и распространять вредоносные программы. Теперь, для того чтобы получить доступ к хакерскому средству, нужно просто знать IP-адрес нужного сайта, а для проведения атаки достаточно щелкнуть мышью.

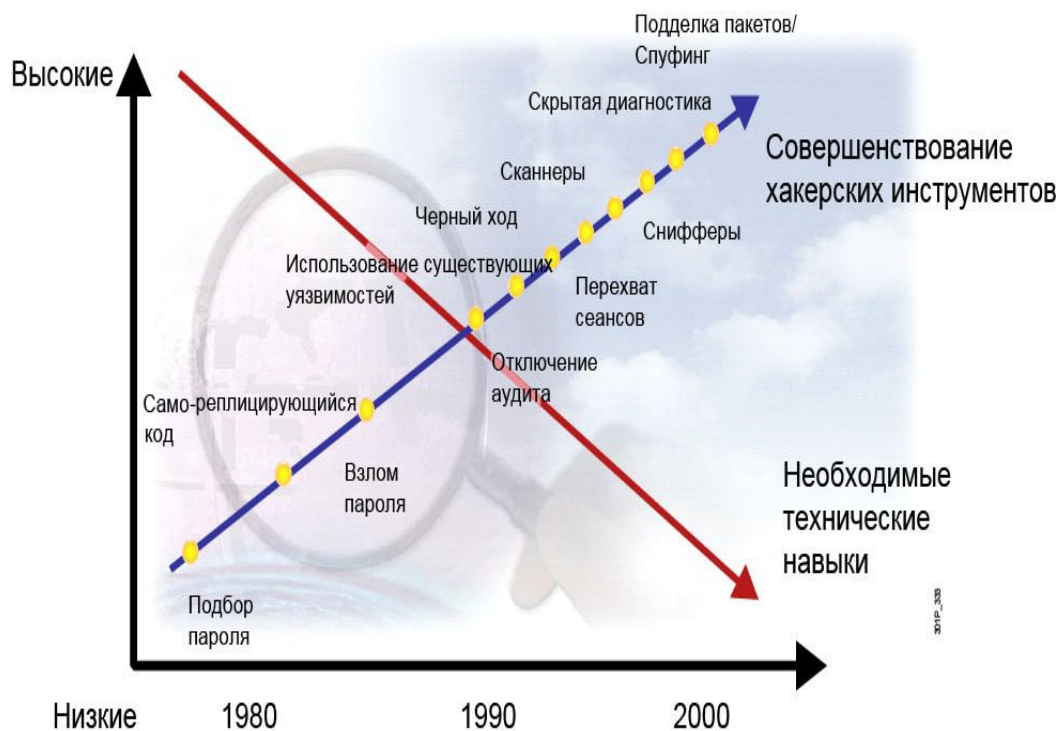


Рисунок 2. Угрозы сети

Сетевые атаки столь же разнообразны, как и системы, против которых

они направлены. Некоторые атаки отличаются большой сложностью. Другие может осуществить обычный оператор, даже не предполагающий, какие последствия может иметь его деятельность. Нарушитель, осуществляя атаку, обычно ставит перед собой следующие цели:

- нарушение конфиденциальности передаваемой информации;
- нарушение целостности и достоверности передаваемой информации;
- нарушение работоспособности системы в целом или отдельных ее частей.

С точки зрения безопасности распределенные системы характеризуются прежде всего наличием удаленных атак, поскольку компоненты распределенных систем обычно используют открытые каналы передачи данных и нарушитель может не только проводить

пассивное прослушивание передаваемой информации, но и модифицировать передаваемый трафик (активное воздействие). И если активное воздействие на трафик может быть зафиксировано, то пассивное воздействие практически не поддается обнаружению.

Трудность выявления факта проведения удаленной атаки выводит этот вид неправомерных действий на первое место по степени опасности, поскольку необнаруживаемость препятствует своевременному реагированию на осуществленную угрозу, в результате чего у нарушителя увеличиваются шансы успешной реализации атаки. Безопасность локальной сети по сравнению с безопасностью межсетевого взаимодействия отличается тем, что в этом случае на первое по значимости место выходят *нарушения зарегистрированных пользователей*, поскольку в основном каналы передачи данных локальной сети находятся на контролируемой территории, защита от несанкционированного подключения, к которым реализуется административными методами.

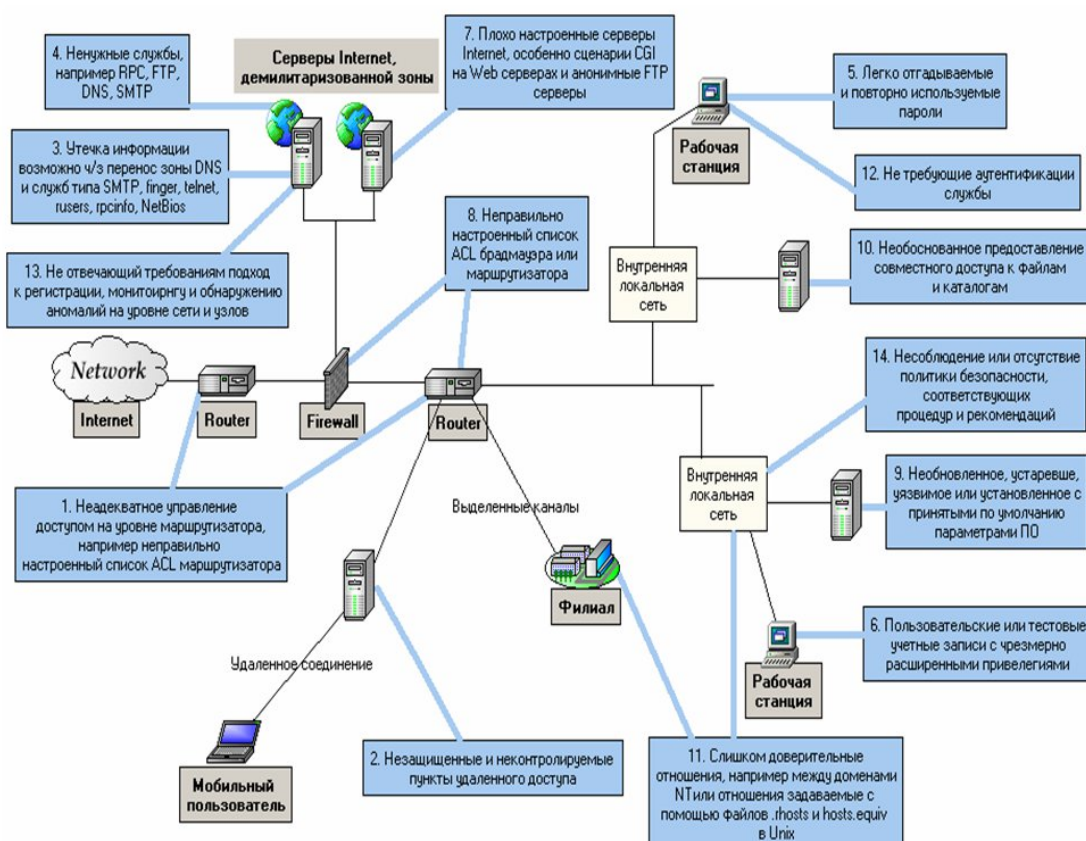


Рисунок 3. Угрозы и уязвимости в сети

2. Виды сетевых атак.



Рассмотрим наиболее распространенные виды сетевых атак.

Подслушивание (Sniffing). По большей части данные по компьютерным сетям передаются в незащищенном формате (открытым текстом), что позволяет заинтересованному лицу, получившему доступ к линиям передачи данных в вашей сети, подслушивать или считывать трафик. Для подслушивания в компьютерных сетях используют сниффер. Сниффер пакетов представляет собой прикладную программу, которая перехватывает все сетевые пакеты, передаваемые через определенный домен. В настоящее время снифферы работают в сетях на вполне законном основании. Они используются для диагностики неисправностей и анализа трафика. Однако ввиду того, что некоторые сетевые приложения передают данные в текстовом формате (Telnet, FTP, SMTP, POP3 и т.д.), с помощью сниффера можно узнать полезную, а иногда и конфиденциальную информацию (например, имена пользователей и пароли). Перехват пароля (Password Sniffing), передаваемого по сети в незашифрованной форме, путем «подслушивания» канала является разновидностью атаки подслушивания. Перехват имен и паролей создает большую опасность, так как пользователи часто применяют один и тот же логин и пароль для множества приложений и систем. Многие пользователи вообще имеют один пароль для доступа ко всем ресурсам и приложениям. Если приложение работает в режиме клиент/сервер, а аутентификационные данные передаются по сети в

читаемом текстовом формате, эту информацию с большой вероятностью можно использовать для доступа к другим корпоративным или внешним ресурсам.

Предотвратить угрозу sniffинга пакетов можно с помощью следующих мер и средств:

- применение для аутентификации однократных паролей;
- установка аппаратных или программных средств, распознающих sniffеры;
- применение криптографической защиты каналов связи.

Изменение данных. Злоумышленник, получивший возможность прочесть ваши данные, сможет сделать и следующий шаг – изменить их. Данные в пакете могут быть изменены, даже если злоумышленник ничего не знает ни об отправителе, ни о получателе. Даже если вы не нуждаетесь в строгой конфиденциальности всех передаваемых данных, наверняка вы не захотите, чтобы они были изменены по пути.

Анализ сетевого трафика. Целью атак подобного типа являются прослушивание каналов связи и анализ передаваемых данных и служебной информации с целью изучения топологии и архитектуры построения системы, добывания критической пользовательской информации. Атакам данного типа подвержены такие протоколы, как FTP и Telnet, особенностью которых является то, что имя и пароль пользователя передаются в рамках этих протоколов в открытом виде. Подмена доверенного субъекта. Большая часть сетей и операционных систем используют IP-адрес компьютера для того, чтобы определять тот ли это адресат, который нужен. В некоторых случаях возможно некорректное присвоение IP-адреса (подмена IP-адреса отправителя другим адресом) – такой способ атаки называют фальсификацией адреса, или IP-спуфингом (IP spoofing).

IP-спуфинг имеет место, когда злоумышленник, находящийся внутри организации или вне ее, выдает себя за законного

пользователя. Он может воспользоваться IP-адресом, находящимся в пределах диапазона санкционированных IP-адресов, или авторизованным внешним адресом, которому разрешается доступ к определенным сетевым ресурсам. Злоумышленник может также использовать специальные программы, формирующие IP-пакеты таким образом, чтобы они выглядели как исходящие с разрешенных внутренних адресов корпоративной сети. Атаки IP-спуфинга часто являются отправной точкой для других атак. Классическим примером является атака типа «отказ в обслуживании» (DoS), которая начинается с чужого адреса, скрывающего истинную личность атакующего.

Угрозу спуфинга можно ослабить (но не устранить) с помощью следующих мер:

- правильная настройка управления доступом из внешней сети;
- пресечение попыток спуфинга чужих сетей пользователями своей сети;
- введение дополнительных методов аутентификации пользователей (на основе одноразовых паролей или других методов криптографии).

Посредничество. Атака типа «посредничество» подразумевает активное подслушивание, перехват и управление передаваемыми данными невидимым промежуточным узлом. Когда компьютеры взаимодействуют на низких сетевых уровнях, они не всегда могут определить, с кем именно они обмениваются данными.

Посредничество в обмене незашифрованными ключами (атака Man-in-the-Middle – «человек-по-середине). Для проведения атаки «человек по-середине» специалистам спецслужб нужен доступ к пакетам, передаваемым по сети. Такой доступ ко всем пакетам, передаваемым от провайдера ISP в любую другую сеть, может, например, получить сотрудник этого провайдера. Для атак этого типа часто используются sniffеры пакетов, транспортные протоколы и

протоколы маршрутизации. В более общем случае атаки «человек-по-середине» проводятся с целью кражи информации, перехвата текущей сессии и получения доступа к частным сетевым ресурсам для анализа трафика и получения информации о сети и ее пользователях, для проведения атак типа DoS, искажения передаваемых данных и ввода несанкционированной информации в сетевые сессии.

Эффективно бороться с атаками типа «человек-по-середине» можно только с помощью криптографии. Для противодействия атакам этого типа используется инфраструктура управления открытыми ключами PKI (Public Key Infrastructure).

Перехват сеанса (Session Hijacking). По окончании начальной процедуры аутентификации пользователем, например, соединение, с установленное законным почтовым сервером, переключается специалистом компьютерной разведки на новый хост, а исходному серверу выдается команда разорвать соединение. В результате «собеседник» законного пользователя оказывается незаметно подмененным.

После получения доступа к сети у атакующего появляются следующие возможности:

- он может посылать некорректные данные приложениям и сетевым службам, что приводит к их аварийному завершению или неправильному функционированию;
- он может также наводнить компьютер или всю сеть трафиком, пока не произойдет остановка системы в связи с перегрузкой;
- наконец, атакующий может блокировать трафик, что приведет к потере доступа авторизованных пользователей к сетевым ресурсам.

Отказ в обслуживании – DoS (Denial of Service). Эта атака отличается от атак других типов. Она не нацелена на получение доступа к вашей сети или на получение из этой сети какой-либо информации. Атака DoS делает сеть организации недоступной для

обычного использования за счет превышения допустимых пределов функционирования сети операционной системы или приложения. По существу, эта атака лишает обычных пользователей доступа к ресурсам или компьютерам сети организации.

Атаки DoS трудно предотвратить, так как для этого требуется координация действий с провайдером. Если трафик, предназначенный для переполнения вашей сети, не остановить у провайдера, то на входе в сеть вы это сделать уже не сможете, потому что вся полоса пропускания будет занята. Если атака этого типа проводится одновременно через множество устройств, мы говорим о распределенной атаке отказа в обслуживании DDoS (Distributed DoS).

Простота реализации атак DoS и огромный вред, причиняемый ими организациям и пользователям, привлекают к этим атакам пристальное внимание администраторов сетевой безопасности.

Парольные атаки. Целью этих атак является завладение паролем и логином законного пользователя. Сотрудники подразделений компьютерной разведки могут проводить парольные атаки, используя такие методы, как: - подмена IP-адреса (IP-спуфинг); - подслушивание (сниффинг); - простой перебор. IP-спуфинг и сниффинг пакетов были рассмотрены выше. Эти методы позволяют завладеть паролем и логином пользователя, если они передаются открытым текстом по незащищенному каналу. Часто хакеры пытаются подобрать пароль и логин, используя для этого многочисленные попытки доступа. Такой подход носит название «атака полного перебора» (Brute Force Attack). Для этой атаки используется специальная программа, которая пытается получить доступ к ресурсу общего пользования (например, к серверу).

Средства перехвата, подбора и взлома паролей в настоящее время считаются практически легальными и официально выпускаются достаточно большим числом компаний. Они позиционируются как

программы для аудита безопасности и восстановления забытых паролей и их можно на законных основаниях приобрести у разработчиков. Парольных атак можно избежать, если не пользоваться паролями в текстовой форме. Использование одноразовых паролей и криптографической аутентификации могут практически свести на нет угрозу таких атак. К сожалению, не все приложения, хосты и устройства поддерживают указанные методы аутентификации.

Угадывание ключа. Криптографический ключ представляет собой код или число, необходимое для расшифровки защищенной информации. Хотя узнать ключ доступа трудно и требует больших затрат ресурсов, тем не менее это возможно. В частности, для определения значения ключа может быть использована специальная программа, реализующая метод полного перебора. Ключ, к которому получает доступ атакующий, называется скомпрометированным. Атакующий использует скомпрометированный ключ для получения доступа к защищенным передаваемым данным без ведома отправителя и получателя. Ключ дает возможность расшифровывать и изменять данные.

Атаки на уровне приложений. Эти атаки могут проводиться несколькими способами. Самый распространенный из них состоит в использовании известных слабостей серверного программного обеспечения (FTP, HTTP, веб-сервера). Главная проблема с атаками на уровне приложений состоит в том, что они часто пользуются портами, которым разрешен проход через межсетевой экран. Невозможно полностью исключить атаки на уровне приложений. Хакеры постоянно открывают и публикуют на своих сайтах в Интернете все новые уязвимые места прикладных программ. Здесь важно осуществлять хорошее системное администрирование, чтобы снизить уязвимость от атак этого типа.

Сетевая разведка – это сбор информации о сети с помощью общедоступных данных и приложений. При подготовке атаки против какой-либо сети хакер, как правило, пытается получить о ней как можно больше информации. Сетевая разведка проводится в форме запросов DNS, эхо-тестирования (Ping Sweep) и сканирования портов. Запросы DNS помогают понять, кто владеет тем или иным доменом и какие адреса этому домену присвоены. Эхо тестирование адресов, раскрытых с помощью DNS, позволяет увидеть, какие хосты реально работают в данной среде. Получив список хостов, хакер использует средства сканирования портов, чтобы составить полный список услуг, поддерживаемых этими хостами. В результате добывается информация, которую можно использовать для взлома.

Злоупотребление доверием. Данный тип действий не является атакой в полном смысле этого слова. Он представляет собой злонамеренное использование отношений доверия, существующих в сети. Типичным примером такого злоупотребления является ситуация в периферийной части корпоративной сети. В этом сегменте обычно располагаются серверы DNS, SMTP и HTTP. Поскольку все они принадлежат к одному и тому же сегменту, взлом одного из них приводит к взлому и всех остальных, так как эти серверы доверяют другим системам своей сети. Риск злоупотребления доверием можно снизить за счет более жесткого контроля уровней доверия в пределах своей сети. Системы, расположенные с внешней стороны межсетевого экрана, никогда не должны пользоваться абсолютным доверием со стороны систем, защищенных межсетевым экраном.

Перечисленные атаки на IP-сети возможны в силу ряда причин:

- использование общедоступных каналов передачи данных. Важнейшие данные передаются по сети в незашифрованном виде;

- уязвимости в процедурах идентификации, реализованных в стеке TCP/IP. Идентифицирующая информация на уровне IP передается в открытом виде;
- отсутствие в базовой версии стека протоколов TCP/IP механизмов, обеспечивающих конфиденциальность и целостность передаваемых сообщений;
- аутентификация отправителя осуществляется по его IP-адресу. Процедура аутентификации выполняется только на стадии установления соединения, а в дальнейшем подлинность принимаемых пакетов не проверяется;
- отсутствие возможности контроля за маршрутом прохождения сообщений в сети Интернет, что делает удаленные сетевые атаки практически безнаказанными.

3. Угрозы и уязвимости беспроводных сетей.

При построении беспроводных сетей одной из наиболее острых проблем является обеспечение их безопасности. Если в обычных сетях информация передается по проводам, то радиоволны, используемые для беспроводных решений, достаточно легко перехватить при наличии соответствующего оборудования. Принцип действия беспроводной сети приводит к возникновению большого количества возможных уязвимостей для атак и проникновений.



Оборудование беспроводных локальных сетей WLAN (Wireless Local Area Network) включает в себя точки беспроводного доступа и компьютеры абонентов. Точки доступа AP (Access Point) выполняют роль концентраторов, обеспечивающих связь между абонентами и между собой, а также

функцию мостов, осуществляющих связь с кабельной локальной сетью и с Интернетом. Каждая точка доступа может обслуживать несколько абонентов. Несколько близко расположенных точек доступа образуют зону доступа Wi-Fi, в пределах которой все абоненты, снабженные беспроводными адаптерами, получают доступ к сети.

Такие зоны доступа создаются в местах массового скопления людей: в аэропортах, студенческих городках, библиотеках, магазинах, бизнес-центрах и т.д. У точки доступа есть идентификатор набора сервисов SSID (Service Set Identifier). SSID – это 32-битная строка, используемая в качестве имени беспроводной сети, с которой ассоциируются все узлы. Идентификатор SSID необходим для подключения рабочей станции к сети. Чтобы связать рабочую станцию с точкой доступа, обе системы должны иметь один и тот же SSID. Если рабочая станция не имеет нужного SSID, то она не сможет связаться с точкой доступа и соединиться с сетью.

Главное отличие между проводными и беспроводными сетями связано с наличием неконтролируемой области между конечными точками беспроводной сети. Это позволяет атакующим, находящимся в непосредственной близости от беспроводных структур, производить целый ряд действий, которые невозможны в проводном мире. При использовании беспроводного доступа к локальной сети угрозы безопасности существенно возрастают (Рис. 4.).



Рисунок 4. Угрозы при беспроводном доступе к локальной сети.

Перечислим основные уязвимости и угрозы беспроводных сетей.

Вещание радиомаяка. Точка доступа включает с определенной частотой широковещательный радиомаяк, чтобы оповещать окрестные беспроводные узлы о своем присутствии. Эти широковещательные сигналы содержат основную информацию о точке беспроводного доступа, включая, как правило, SSID, и приглашают зарегистрироваться беспроводные узлы в данной области. Любая рабочая станция, находящаяся в режиме ожидания, может получить SSID и добавить себя в соответствующую сеть. Вещание радиомаяка является врожденной патологией беспроводных сетей. Многие модели позволяют отключать содержащую SSID часть этого вещания, чтобы несколько затруднить беспроводное подслушивание, но SSID тем не менее посылается при подключении, поэтому все равно существует небольшое окно уязвимости.

Обнаружение WLAN. Для обнаружения беспроводных сетей WLAN используется, например, утилита NetStumber совместно со

спутниковым навигатором глобальной системы позиционирования GPS. Данная утилита идентифицирует SSID сети WLAN, а также определяет, используется ли в ней система шифрования WEP. Применение внешней антенны на портативном компьютере делает возможным обнаружение сетей WLAN во время обхода нужного района или поездки по городу. Надежным методом обнаружения WLAN является обследование офисного здания с переносным компьютером в руках.

Подслушивание. Подслушивание ведут для сбора информации о сети, которую предполагается атаковать впоследствии. Перехватчик может использовать добытые данные для того, чтобы получить доступ к сетевым ресурсам. Оборудование, используемое для подслушивания в сети, может быть не сложнее того, которое применяется для обычного доступа к этой сети. Беспроводные сети по своей природе позволяют соединять с физической сетью компьютеры, находящиеся на некотором расстоянии от нее, как если бы эти компьютеры находились непосредственно в сети. Это позволяет подключиться к беспроводной, сети, располагающейся в здании, человеку, сидящему в машине на стоянке рядом с ним. Атаку посредством пассивного прослушивания практически невозможно обнаружить.

Ложные точки доступа в сеть. Опытный атакующий может организовать ложную точку доступа с имитацией сетевых ресурсов. Абоненты, ничего не подозревая, обращаются к этой ложной точке доступа и сообщают ей свои важные реквизиты, например аутентификационную информацию. Этот тип атак иногда применяют в сочетании с прямым глушением, чтобы заглушить истинную точку доступа в сеть.

Отказ в обслуживании. Полную парализацию сети может вызвать атака типа «отказ в обслуживании» (DoS). Цель любой атаки отказа в обслуживании состоит в создании помехи при доступе пользователя к

сетевым ресурсам. Беспроводные системы особенно восприимчивы к таким атакам. Физический уровень в беспроводной сети – абстрактное пространство вокруг точки доступа. Можно включить устройство, заполняющее весь спектр на рабочей частоте помехами и нелегальным трафиком – такая задача не вызывает особых трудностей. Сам факт проведения DoS-атаки на физическом уровне в беспроводной сети трудно доказать.

Атаки типа «человек-в-середине». Атаки типа «человек-в-середине» выполняются на беспроводных сетях гораздо проще, чем на проводных, так как к проводной сети требуется реализовать определенный вид доступа. Обычно атаки «человек-в-середине» используются для нарушения конфиденциальности и целостности сеанса связи. Атаки «человек-в-середине» более сложны, чем большинство других атак: для их проведения требуется подробная информация о сети. Спецслужбы обычно подменяет идентификацию одного из сетевых ресурсов, после чего используют возможность прослушивания и нелегального захвата потока данных с целью изменения его содержимого, необходимого для выполнения своих задач.

Анонимный доступ в Интернет. Незащищенные беспроводные ЛВС (локальные вычислительные сети) обеспечивают хакерам наилучший анонимный доступ для атак через Интернет. Хакеры могут использовать незащищенную беспроводную ЛВС организации для выхода через нее в Интернет, где они будут осуществлять противоправные действия, не оставляя при этом своих следов. Организация с незащищенной ЛВС формально становится источником атакующего трафика, нацеленного на другую компьютерную систему, что связано с потенциальным риском правовой ответственности за причиненный ущерб жертве атаки хакеров. Атаки, используемые

хакерами для взлома беспроводных сетей, не ограничиваются описанными выше.